Corporate Innovation Challenge – AI-Z Group GmbH

Titel: Sensible Daten und KI-Kontrollen prüfen

Unsere Produkte sollen sensible Daten vor ungeschützter Weitergabe an KI-Modelle schützen. Ihr prüft den bereitgestellten Build mit erfundenen Testdaten und belegt Schwachstellen nachvollziehbar. Jedes Team bearbeitet beide Testbereiche.

Challenge:

Testbereich A:
Browser-Erweiterung auf dem eigenen Laptop.

A1 Übersehene sensible Daten (HOCH)

Erfundene sensible Daten finden, die unerkannt im Klartext zum Modell gelangen. Testet etwa IBANs, Telefonnummern, Adressen, Steuer-IDs, Geburtsdaten, Passwörter, API-Schlüssel, ausländische Formate und andere Sprachen.

Zählt nicht: Passwörter unter 12 Zeichen; IP-Adressen (standardmäßig aus).

A2 Versand an der Prüfkarte vorbei (HOCH)

Alltägliche Wege finden, auf denen Daten ohne Prüfkarte das Produkt verlassen. Beispiele: gesendete Nachricht bearbeiten, Regenerieren, Tastenkürzel, Spracheingabe, Autofill, anderes Eingabefeld und schnelles Doppel-Senden.

Zählt nicht: wiederhergestellte Werte auf der Seite des KI-Dienstes und Seitenübersetzung.

A3 Umgehung einer KI-Sperre (MITTEL)

Trotz gesperrtem KI-Tool ein Modell derselben Klasse über die freigegebene Browser-Umgebung erreichen. Erlaubt: andere Domains, mobile oder regionale Adressen, eingebettete KI und Wrapper.

Nicht erlaubt: anderer Browser oder anderes Gerät, Desktop-App, API, VPN, Edge-Sidebar und Inkognito.

A4 Unbekannte KI-Webseiten (MITTEL)

Eigenständige KI-Seiten finden, die der Katalog des Event-Builds noch nicht erkennt.

Bonus: eine ganze Klasse von Seiten statt einzelner URLs. Punkte pro Team gedeckelt.

Testbereich B
Brane AIF vor der KI

Auch dieser Testbereich ist für jedes Team verbindlich. AIF nur nach erfolgreichem Probelauf und ausdrücklicher Freigabe der Event-Umgebung. AIF-Testzeitfenster mit dem Meldedesk abstimmen.

Zugang: Browser und bereitgestellte Testkonten.

B1 Sensible Daten im Cloud-Aufruf (HOCH)

Erfundene Namen, IBANs oder E-Mails im Klartext im Cloud-Aufruf nachweisen, obwohl das Produkt sie ersetzen soll. Probiert kurze Eingaben, ungewöhnliche Formate und Mischungen.

Die ausliegende Liste der geschützten Datenarten ist maßgeblich.

B2 Lokale Verarbeitung (HOCH)

Prüfen, ob eine spätere Nachricht aus einem als sensibel eingestuften lokalen Kontext zum Cloud-Modell gelangt.

B3 Grenzen zwischen Testkonten (HOCH)
Mit bereitgestellten Konten prüfen, ob normale Nutzer auf ausdrücklich freigegebene fremde Testchats oder Admin-Funktionen zugreifen können.

Server, Betriebssystem und Netzwerk sind ausgeschlossen.

B4 Verhalten bei Störungen (HOCH)

Unter begrenzter Last und simulierten Störungen prüfen, ob der vorgegebene lokale Schutz erhalten bleibt.

Nur nach Freigabe durch den Meldedesk auf der Event-Box, unter dessen Aufsicht und in festgelegten Zeitfenstern mit Lastgrenzen. Bei einem Stopp sofort aufhören. B4-Funde: direkt an den Meldedesk, nicht an eine öffentliche Wand.

Regeln für beide Testbereiche

Nur erfundene Testdaten. Nur ausdrücklich freigegebene Produktflächen und bereitgestellte Testkonten. Rechner, Server, Betriebssystem, Netzwerk und fremde Konten außerhalb der Aufgabe sind ausgeschlossen. Keine Prompt Injection.

Lasttests und simulierte Störungen nur nach Freigabe und unter Aufsicht des Meldedesks mit festgelegten Lastgrenzen. Bei einem Stopp sofort aufhören. Funde vertraulich melden, nicht veröffentlichen. Keine Weitergabe der Software nach dem Event.

Funde melden und bewerten
Abgabe und Pitch

Jeden Fund im Meldeformular dokumentieren. Eine zweite Person bestätigt den Fund. B4: Direkt an den Meldedesk, nicht an eine öffentliche Wand.

Das gehört in jede Meldung

1. Testbereich und Aufgaben-ID
2. Build und Testdaten
3. Schritte zum Nachstellen
4. Screenshot oder passender Nachweis
5. Erwartetes und tatsächliches Verhalten

So wird bewertet

Hoch: A1, A2, B1, B2, B3 und B4. Mittel: A3 und A4. Bonus: Nachvollziehbarkeit, Priorisierung, möglicher Schaden und Verbesserungsvorschlag.

Ein Fund zählt einmal. Bei demselben Fund zählt die erste Meldung. Punkte pro Aufgabe sind gedeckelt. Bekannte oder nicht freigegebene Fälle zählen nicht. A4: Punkte pro Team gedeckelt

Das zeigt ihr im Pitch

Ergebnisse aus beiden Testbereichen; die drei wichtigsten Funde; Nachweis und mögliche Auswirkung; Vorschlag für die Verbesserung.

Beantwortet außerdem: Was würde euch zum Einsatz bewegen, ohne dass eine Firma es verlangt? Welche Funktion fehlt euch?

Zeiten und Vorbereitung
Kickoff: Freitag ab 17:00 Uhr. Abgabe: Samstag 13:30 Uhr. Pitches: Samstag ab 15:00 Uhr. Preisverleihung: Samstag 16:30 Uhr.
Browser-Erweiterung: aktueller Chrome, Edge oder Brave. Möglichst mindestens 8 GB RAM. Nach Anmeldung das lokale Modell vollständig laden. Brane AIF: Browser und bereitgestellte Testkonten. Installation, Zugriff und Testdaten beim Kickoff prüfen.

Die Aufgaben prüfen den bereitgestellten Build. Funde sind keine unabhängige Sicherheitszertifizierung.

CORPORATE INNOVATION CHALLENGE

REUTLINGEN UNIVERSITY CENTER FOR ENTREPRENEURSHIP

Corporate Innovation Challenge – AI-Z Group GmbH

Titel: Testing Sensitive Data and AI Controls

Our products are designed to protect sensitive data from being disclosed to AI models without protection. You will test the provided build using fictional test data and document vulnerabilities in a reproducible manner. Every team must work on both test areas.

Challenge:

Test Area A:
Browser extension on your own laptop.

A1 Undetected Sensitive Data (HIGH)

Find fictional sensitive data that reaches the model in plain text without being detected. Test, for example, IBANs, phone numbers, addresses, tax IDs, dates of birth, passwords, API keys, foreign formats, and other languages.

Not counted: passwords shorter than 12 characters; IP addresses (disabled by default).

A2 Sending Data Bypassing the Review Card (HIGH)

Find common ways for data to leave the product without passing through the review card. Examples: editing a sent message, regenerating, keyboard shortcuts, voice input, autofill, another input field, and rapidly double-clicking Send.

Not counted: values restored on the AI service's side and page translation.

A3 Bypassing an AI Block (MEDIUM)

Access a model of the same category through the permitted browser environment despite the AI tool being blocked. Allowed: other domains, mobile or regional addresses, embedded AI, and wrappers.

Not allowed: another browser or device, desktop app, API, VPN, Edge Sidebar, and Incognito mode.

A4 Unknown AI Websites (MEDIUM)

Find standalone AI websites that are not yet recognized by the event build's catalog.

Bonus: identifying an entire class of websites rather than individual URLs. Points per team are capped.

Test Area B
Brane AIF in front of AI

This test area is also mandatory for every team. Test AIF only after a successful trial run and explicit approval of the event environment. Coordinate AIF testing windows with the reporting desk.

Access: browser and provided test accounts.

B1 Sensitive Data in Cloud Requests (HIGH)

Demonstrate that fictional names, IBANs, or email addresses are transmitted in plain text in cloud requests, even though the product is supposed to replace them. Try short inputs, unusual formats, and combinations.

The provided list of protected data types is authoritative.

B2 Local Processing (HIGH)

Check whether a subsequent message from a local context classified as sensitive reaches the cloud model.

B3 Boundaries Between Test Accounts (HIGH)

Using the provided accounts, check whether regular users can access explicitly shared third-party test chats or admin functions.

Servers, operating systems, and networks are out of scope.

B4 Behavior Under Disruptions (HIGH)

Under limited load and simulated disruptions, check whether the specified local protection remains in place.

Only on the event box, with approval from the reporting desk, under its supervision, and within designated time windows and load limits. Stop immediately if instructed. B4 findings must be reported directly to the reporting desk, not on a public board.

Rules for Both Test Areas

Use fictional test data only. Test only explicitly approved product areas and provided test accounts. Computers, servers, operating systems, networks, and third-party accounts outside the scope of the challenge are excluded. No prompt injection.

Load testing and simulated disruptions are only permitted with approval and under the supervision of the reporting desk, subject to defined load limits. Stop immediately if instructed. Report findings confidentially; do not publish them. Do not distribute the software after the event.

Reporting and Evaluation of Findings
Submission and Pitch

Document every finding in the reporting form. A second person must confirm the finding. B4: Report directly to the reporting desk, not on a public board.

Every report must include:

1. Test area and task ID
2. Build and test data
3. Steps to reproduce
4. Screenshot or relevant evidence
5. Expected and actual behavior

How scoring works

High: A1, A2, B1, B2, B3, and B4. Medium: A3 and A4. Bonus: reproducibility, prioritization, potential impact, and proposed improvement.

Each finding counts once. For duplicate findings, the first report counts. Points per task are capped. Known or unauthorized cases do not count. A4: Points per team are capped.

What to present in your pitch

Results from both test areas; your three most important findings; evidence and potential impact; proposed improvements.

Also answer: What would convince you to use the product without a company requiring it? Which feature are you missing?

Timing and Preparation

Kickoff: Friday from 17:00. Submission: Saturday at 13:30. Pitches: Saturday from 15:00.
Award ceremony: Saturday at 16:30.

Browser extension: current Chrome, Edge, or Brave. At least 8 GB RAM recommended.
After registration, fully download the local model. Brane AIF: browser and provided test accounts.
Check installation, access, and test data during the kickoff.

The tasks evaluate the provided build. Findings do not constitute an independent security certification.